CTF-Web安全学习路线

- 注意事项
  - 我是使用vscode+git+markdown记笔记，使用有道、映像等等也都行，个人喜好
  - 学习的过程一定要记笔记，web安全技术又多又杂，累积起来的笔记不仅能帮助你在比赛中即使回忆起知识点还能帮助你一定的成就感
  - 任何语言的编程都一定要会调试代码，不然解决复杂点的漏洞你就会看不明白，所有要从开始养成调试的习惯
  - web安全是看重实践能力的，不要眼高手低，漏洞看懂了不等于会挖，有一大堆看懂writeup但给你自己试就打不通的例子

1 编程基础（前期）

- html
  - 怎么学？ — https://www.runoob.com/html/html5-intro.html
  - 最低要求
    - 理解html网页的构成
    - 能自己写一个能发请求的登录页面
- javascript
  - 怎么学？ — https://www.runoob.com/js/js-tutorial.html
  - 最低要求
    - 初步理解DOM和BOM
    - 能使用js获取DOM元素，操控DOM树
    - 能自己写一个网页端的四则运算计算器
- css
  - 怎么学？ — https://www.runoob.com/css/css-tutorial.html
  - 最低要求 — 会用css选择器
- php
  - 怎么学？
    - https://www.runoob.com/php/php-tutorial.html
    - 使用phpstudy或者WampServer傻瓜式安装全套，对着菜鸟教程学习，边看边敲代码
  - 最低要求
    - 了解php基本语法
    - 用户名密码以数组的形式存在php文件里，能够编写一个简单登录系统
    - 懂得如何调试php代码
- http
  - 怎么学 — 百度http协议是什么，浏览器与服务器是如何通信的，配合你的php知识，配合浏览器的f12功能，理解浏览器是如何向你的php网站的
  - 最低要求
    - 理解url的基本构成
    - http请求头、响应头常见的有哪些？是干嘛的？
    - Get、Post方法有什么区别？
    - http响应码有哪些？
    - 面对http请求报文和响应报文能理解它的意义
- mysql
  - 怎么学
    - https://www.runoob.com/mysql/mysql-tutorial.html
    - 安装mysql，先在命令行熟悉mysql中建库建表查数据等操作，再尝试使用php控制mysql数据库
  - 最低要求
    - mysql数据库数据表以及内容的增删改查命令做到认识
    - 能够使用php连接mysql，将用户名密码存储在mysql的一个表里，编写一个简单登录系统
- python
  - 怎么学
    - https://www.runoob.com/python/python-intro.html
    - 直接学python3，有php的基础，python上手很快
  - 最低要求
    - 了解python基本语法
    - 能够编写一个网络爬虫（requests+re模块），爬取百度贴吧某个吧下前10页帖子的名字
    - 会调试python代码

2 基础漏洞（中期）

- 了解常见概念
  - 漏洞
  - OWASP TOP 10
  - 抓包
  - 暴力破解
  - payload
  - poc
  - exp
  - writeup
  - github
  - webshell
  - 0day/1day/nday
- 信息收集
  - 前端代码泄漏
    - 注释
    - href、src、action、jsf代码暴露隐藏url
    - hidden的表单
  - 目录扫描
    - https://github.com/maurosoria/dirsearch
    - 源码泄漏：常见备份文件/.git/.hg/.svn/vim缓存
    - 敏感目录泄漏：robots.txt/.DS_Store/admin/upload
- SQL注入
  - 怎么学
    - 百度了解sql注入是什么东西？怎么产生的？有什么危害？如何利用？了解基本概念
    - https://github.com/Audi-1/sqli-labs 如何使用sqli-labs网上很多教程，答案网上也很多
    - 当你手动至少能通关sqli-labs前9关后，可以学习sqlmap这个工具，体会使用脚本的爽快，使用sqlmap来打sqli-labs试试
    - https://buuoj.cn/ 在buuctf搜索sql相关的ctf真题来练手，关注一些新生赛的题目比较容易接受，如国赛大挑战 2019[Easy]SQL
    - 尝试修复sqli-labs前9关的漏洞，你有几种修复方案？
  - 最低要求
    - 理解sql注入漏洞形成的原因
    - 面对sqli-labs前9关能够注出任意数据库任意数据表重要的任意数据
    - 能够修复sqli-labs中出现的sql注入漏洞
- burpsuite
  - 怎么学
    - https://www.bilibili.com/video/BV1aq4y1X7o0?p=14vd_source=f808cbc395a0b7444beaebddd9515d62
    - 带上burpsuite来进行打靶sqli-labs吧
  - 最低要求
    - 能使用proxy模块进行抓包放包
    - 熟练repeaster模块的使用，用它来进行sql注入的测试
    - 能使用intruder模块进行爆破，如用它来sql盲注出一位正确字符
- 文件上传
  - 怎么学
    - 百度了解文件上传漏洞是什么东西？怎么产生的？有什么危害？如何利用？了解基本概念
    - https://github.com/c0ny1/upload-labs
    - https://buuoj.cn/ 在buuctf搜索upload相关的ctf真题来练手，关注一些新生赛的题目比较容易接受，如2021ACTF2020 新生赛的upload
    - 尝试修复upload-labs的漏洞，你有几种修复方案？
  - 最低要求
    - 会写php的webshell
    - 明白webshell使用的原理
    - 熟悉文件上传的常见绕过方法（绕后缀名，绕文件头，绕MIME等）
    - 能够修复upload-labs的漏洞
- 阶段总结
  - 漏洞的普遍学习方法
    - 通过搜索引擎了解漏洞是什么？如何产生？有何危害？如何利用？在脑中形成对该漏洞的基本概念
    - 该漏洞是否有前人总结的训练靶场。有则直接拿来用，没有则自己搭建简单的漏洞环境进行测试
    - 尽量复现出该漏洞能产生的所有危害，不要直接使用别人的exp脚本或者自动攻击工具。
    - 熟悉手工编payload利用后，可以使用工具攻击
    - 学习如何修复漏洞，保证自己的漏洞环境不再会被工具或者那有payload攻击
    - 现在这个漏洞可以说已经学会了，想要继续进阶可以继续
    - 找相关的CTF题目练习
    - 阅读大佬开发的利用工具源码，学习别人的攻击姿势
    - 阅读漏洞相关技术的文档，从中提取优化payload或者加重漏洞危害的技巧。如：对于log4j漏洞绕过dns的源码发现有一些字符替换的语法能够伪装我们的payload从而绕waf
  - 通用漏洞靶场推荐
    - https://github.com/zhuifengshaonianhanlu/pikachu 漏洞比较全，后面的很多漏洞可以直接用这个测试
- 命令执行
  - 最低要求
    - 熟悉常见的php代码执行和命令执行的函数
    - 熟悉常见的绕过方法（编码绕过、字符串拼接绕过、无字母数字代码执行等）
    - 无回显的命令执行利用（反弹shell、写文件、dnslog请求外带等）
- 文件包含
  - 最低要求
    - 能够利用文件包含实现 读取普通文件/php文件 命令执行
    - 熟悉文件包含常用的php伪协议的使用方法（php://filter、php://input、data、zip、phar、compress）
    - 文件包含配合文件上传的组合拳
- XSS
  - 最低要求
    - 能够利用DOM-XSS 反射XSS 存储XSS来盗取用户cookie
    - 会用至少一个xss平台
- CSRF
  - 最低要求 — 能够编写get型和post型csrf的poc
- SSRF
  - 最低要求
    - 使用SSRF进行文件读取、未授权攻击redis
    - 熟悉gopher、http、file、dict协议的SSRF利用方式
- XXE
  - 最低要求 — 能够分别在有回显和无回显的情况下使用XXE读取文件
- 反序列化
  - 最低要求
    - 能肉眼看懂php各种数据类型的序列化字符串
    - 熟悉常见的php的魔术方法含义
    - 能够编写pop链，从反序列化触发到目标恶意代码

同时熟悉漏洞成因和漏洞修复

3 进阶学习（后期）

- 多多参与最近的CTF赛事
  - 紧跟时代潮流，刷的题都是旧的。当下比赛的题目往往更加前沿和流行，紧跟技术热点很重要
  - 可以先从容易的比赛开始，如极客大挑战、UNCTF、各个大学的新生赛等等
  - 找一群伙伴一起打，找到团队竞技的氛围，成长更快
  - https://www.ctfhub.com/#/index 推荐ctfhub查看最近的比赛官方榜
  - 赛后根据WP针对看罢习自己需要补充的知识，比如考到了java反序列化，就去学习java反序列化漏洞，而不是仅仅停留在会做比赛时不会做的那道题，否则下次碰到个变体还是不会
- 潜入几个CTF交流比赛群
  - 有很多志同道合的伙伴一起交流学习心得
  - 一些比赛结束后会有师傅在群里分享writeup
- 多看其他师傅的技术博客 — 多看别人的思路，拓展你的视野，同一个问题往往有很多种解法，多看一种你就多一种技巧
- 漏洞复现
  - 在著名组件出现漏洞时第一时间复现，如：log4j2、spring等
  - 复现经典漏洞，学习经典漏洞的攻击技巧。如：fastjson的反序列化、wordpress的后台RCE
  - 有一些漏洞复现经验后，尝试在github上找一些star数比较少的系统挖掘0day提交给开发者，注意issue，可能会有其他白帽提出的漏洞也可以看看
- 未来查漏补缺可能会遇到的
  - python安全
    - jinja2模板注入
    - flask session安全
    - pickle反序列化
    - .....
  - java安全
    - java反序列化
    - java相关组件的nday
    - servlet/spring特性
    - .....
  - nodejs安全
    - 原型链污染
    - vm沙箱逃逸
    - .....
  - go安全
    - 模板注入
    - 整数溢出
    - .....

CTF中经常会穿插考一些php特性，可以在过程中慢慢学习

- php特性trick
  - 弱类型比较
  - 不同对象用md5
  - 函数绕过
    - strcmp()绕过
    - strpos()绕过
    - ereg()绕过
    - file_exists()绕过
    - preg_match()绕过
    - strlen()绕过
    - is_numeric()绕过
    - in_array()绕过
  - 伪随机数漏洞
  - phpinfo信息泄漏
    - disable_functions
    - open_basedir
    - CONTEXT_DOCUMENT_ROOT
    - auto_append_file
    - auto_prepend_file

Presented with xmind